♋ האוניברסיטה הפתוחה

20940

מבוא לאבטחת המרחב המקוון

חוברת מטלות סתיו 2026 א

כתב: יצחק בייז

אוקטובר 2025 – סמסטר סתיו – תשפ"ץ

פנימי – לא להפצה.

© כל הזכויות שמורות לאוניברסיטה הפתוחה.

מטלת מנחה (ממ"ן)01

הקורס: 20940 – מבוא לאבטחת המרחב המקוון

חומר הלימוד למטלה: פרק 1 במדריך הלמידה

מספר השאלות: 5 **משקל המטלה:** ללא נקודות

סמסטר: 2026A **מועד אחרון להגשה** 22/11/2025

הוראות: נא להגיש במערכת המטלות בלבד.

שאלה 1

קראו את הטקסט של הפודקאסט של רן לוי בנושא הנדסה חברתית:

https://www.osimhistoria.com/osimhistoria/oh_ep_063

כתבו מה התחדש לכם בטקסט (ואם כלום לא התחדש – הסבירו מדוע).

שאלה 2

קראו את חלקים 1-3 וחלק 6 בדו"ח החדירות של verison של שנת 2023 (מבוא, תוצאות וניתוח, סווג תקריות וסיכום).

https://www.verizon.com/business/resources/T1ec/reports/2023-data-breach-investigations-report-dbir.pdf

(אין חובה להירשם, ניתן ללחוץ על view only).

סכמו בקצרה וחוו דעתכם על מה שלמדתם מהדו"ח (עד עמוד).

שאלה 3

רשמו שלוש מסקנות שניתן להסיק מאיור 1.2 בספר הקורס, והביאו דוגמה לכל אחת מהן.

שאלה 4

פתרו את שאלה 1.1 ממדריך הלמידה (עמ' 47).

שאלה 5

פתרו את בעיות 14.4, 15.3 ו-17.9 בספר הקורס.

מטלת מנחה (ממ"ן) 02

הקורס: 20940 – מבוא לאבטחת המרחב המקוון

חומר הלימוד למטלה: פרקים 2-3 במדריך הלמידה

מספר השאלות: 5 **משקל המטלה:** ללא נקודות

סמסטר: 2026A **מועד אחרון להגשה** 06/12/2025

הוראות: נא להגיש במערכת המטלות בלבד.

שאלה 1

פתרו את בעיות 20.6 ו- 20.14 בספר הקורס (עמ' 653/4).

שאלה 2

א. פתרו את בעיה 21.7 בספר הקורס (עמ' 680). האם אין בפתרון השאלה סתירה לבטיחות RSA?

ב. אליס שולחת הודעה M (לא מוצפנת) לבוב ובנוסף את חתימתה (בשיטת RSA) על ההודעה (לא על hash שלה). הראו כיצד ניתן ליצור הודעה אחרת (לאו דווקא בעלת משמעות) עם חתימה תקפה של אליס (ללא ידיעת המפתח הפרטי שלה כמובן).
האם ניתן לעשות זאת אם היא הייתה חותמת על hash של ההודעה?

שאלה 3

מחשבים קוואנטים "אפקטיביים" (כלומר שמסוגלים לפתור בעיות שאינן "צעצוע") עדיין אינם קיימים, אך עם זאת יש טענות לפריצת דרך בנושא (לצד טענות אחרות). בכל מקרה, ידוע שאם מחשבים "אפקטיביים" שכאלה יהפכו למציאות, שתי בעיות יקבלו פתרונות יעילים:

- לבעיית הפרוק לגורמים יהיה פתרון בזמן לוגריתמי
- לבעיית החיפוש ברשימה באורך N יהיה פתרון בזמן שורש N

הסבירו איזו השפעה (אם בכלל) תהיה לפתרון בעיות אלו על:

- הצפנה סימטרית (בהתמקדות על AES)
- הצפנה אסימטרית (בהתמקדות על RSA)
- פונקציות HASH בטוחות (בהתמקדות על מציאת התנגשויות)

(ניתן להעזר במאמר שכותרתו "The Impact of Quantum Computing on Present Cryptography")

שאלה 4

השימוש ב- One Time Pad (OTP) ידוע כאמין ובטוח באופן מלא. לפיכך הציע פרופ׳ ניק שטוט מאונ׳ שטוטגרט כי אם אנו דורשים רק בטיחות כמעט מלאה, ניתן להשתמש במפתח יותר מפעם אחת (נאמר 2-5 פעמים). האם לדעתכם הוא צודק? הצדיקו את תשובתכם.

כמו כן, תלמידו אדם א. טוען כי ניתן להצפין את אותה הודעה פעמיים עם מפתח OTP שונה בכל פעם, ללא סיכון לבטיחות. האם לדעתכם הוא צודק? הצדיקו את תשובתכם.

שאלה 5

תארו את הפונק׳ bcrypt (למשל מתוך https://en.wikipedia.org/wiki/bcrypt). הסבירו למה היא משמשת, תארו את האלג׳ העומד בליבה, והסבירו כל שלב בו.

מטלת מנחה (ממ"ן) 03

הקורס: 20940 – מבוא לאבטחת המרחב המקוון

חומר הלימוד למטלה: פרקים 4-5 במדריך הלמידה

מספר השאלות: 5 **משקל המטלה:** ללא נקודות

סמסטר: 2026A **מועד אחרון להגשה:** 20/12/2025

הוראות: נא להגיש במערכת המטלות בלבד.

שאלה 1

נתונה מערכת בעלת שלושה משתמשים, v_1, v_2, v_3 ושלושה קבצים, f_1, f_2, f_3 .

משתמש v_1 יכול לקרוא ולכתוב לקובץ f_1 ולכתוב לקבצים f_2, f_3 (בלבד).

משתמש v_2 יכול לקרוא מ- f_1 , לקרוא ולכתוב ל- f_2 , ולכתוב ל- f_3 (בלבד).

משתמש v_3 יכול לקרוא מ- f_1, f_2 , ולקרוא ולכתוב ל- f_3 (בלבד).

- כתבו מטריצת גישה המתארת את המערכת.
- ייצגו את המטריצה באמצעות רשימות גישה (ACLים).
- ייצגו את המטריצה באמצעות רשימות יכולת (Capability List).
- האם ניתן לייצג את המערכת ביוניקס קלאסי (9 ביט הרשאות)? נמקו.
- האם ניתן לייצג את המערכת ב-Windows? נמקו.
- האם יכול להיות מודל BLP המתאר מערכת זו? נמקו.
- האם יכולה להיות זרימת אינפורמציה במערכת זו? נמקו.
- האם יכול להיות ערוץ נסתר במערכת זו? נמקו.

שאלה 2

א. הסבירו על הפקודות getfacl ו- setfacl ב-Linux. ניתן להיעזר ב-
https://www.redhat.com/sysadmin/linux-access-control-lists.

ב. קראו ב:
https://web.mit.edu/rhel-doc/5/RHEL-5-manual/Deployment_Guide-en-US/ch-selinux.html
ופרטו (עד עמוד) על SELinux.

שאלה 3

ביחס לפרוטוקול קרברוס, הסבירו:

א. מדוע חשוב סנכרון בין כל המחשבים?

ב. מדוע יש צורך ב-TGS?

ג. מדוע האויב אינו יכול לבצע את הפעולות האלה:

[1] לשחק את תפקיד ה-AS או ה-TGS או ה-V.

[2] לשחק את תפקיד הלקוח מול כל אחד מהישויות שלעיל.

ד. את ההבדלים העיקריים שבין גרסה 4 לגרסה 5 של קרברוס (על פי וויקיפדיה או כל מקור רלוונטי).

ה. כיצד (ובאילו תנאים) ניתן לבצע התקפת מילון אופליין כנגד סיסמת המשתמש.

שאלה 4

הפרוטוקול הבא מוצע לאבטחת התקשורת בין לקוח לבנק:

1. הלקוח מתחבר לאתר הבנק באמצעות ת"ז וסיסמא.
2. הבנק שולח ללקוח מספר בן כ-8 ספרות (R) כ-random challenge. (nonce)
3. הלקוח מצפין את R באמצעות מפתח המשותף לו ולבנק (שידוע לשניהם מראש) **אך ייחודי עבור הלקוח** ושולח לבנק את המספר מוצפן.
4. הבנק מזהה את הלקוח וכל יתר התקשורת בין הלקוח לבנק מאובטחת בפרוטוקול תקשורת מוצפן ומאובטח שניתן לסמוך עליו (לדוגמא SSL).

הערה: באם לא נאמר במפורש אזי יש להניח שהמידע מועבר לא מוצפן.

א. מהן בעיות האבטחה החמורות בפרוטוקול המוצע?

ב. הציעו את התיקון הפשוט ביותר הפותר את הבעיות שהצגתם בסעיף א' מבלי ליצור בעיות אבטחה חדשות ומבלי לשנות את התשתית הקיימת.

הערה 2: פגיעה בתשתית הקיימת יכולה לבוא לידי ביטוי בהוספת ישות נוספת שלוקחת חלק בתהליך, יצירה של מפתחות הצפנה נוספים, וכו'.

שאלה 5

א. ציינו עבור אלו מהמנגנונים הבאים ניתן ו/או קל לייצג את ההרשאות הבאות:

(a) Ken wants his files readable by everyone except his office mate.
(b) Mitch and Steve want to share some secret files.
(c) Linda wants some of her files to be public.

המנגנונים הם:

1. רשימות גישה (ACL)
2. רשימות יכולת (c-list)
3. הרשאות קבצים ב-Unix
4. הרשאות קבצים ב- Windows-NT

ב. תנו דוגמה לפגיעות Buffer Overflow אשר לא תיעצר ע"י אחת מההגנות הבאות (או שילוב שלהן):

ASLR – רנדומיזציה של פונקציות המערכת

DEP – מניעת הרצת קוד על המחסנית

CANARY – כתיבת ערך ע"י הקומפיילר לפני כתובת החזרה

הסבירו מדוע.

מטלת מנחה (ממ״ן) 04

הקורס: 20940 – מבוא לאבטחת המרחב המקוון

חומר הלימוד למטלה: פרקים 6-7 במדריך הלמידה

מספר השאלות: 5 **משקל המטלה:** ללא נקודות

סמסטר: 2026A **מועד אחרון להגשה:** 03/01/2026

הוראות: נא להגיש במערכת המטלות בלבד.

שאלה 1

<u>סעיף א׳</u>

נניח שאנו בונים אפליקציית WEB המבקשת מהמשתמש את כתובת האימייל שלו ושומרת אותה במשתנה strUserMailAddress. כמו כן, לאחר שהמשתמש מכניס את כתובתו ולוחץ על OK, אנו רוצים שהאפליקצייה תשלח לו אימייל (עם פרטים כלשהם). לשם כך נכתבה התוכנית הבאה (בפסאודו-קוד), שמקבלת את כתובת האימייל כקלט וקוראת לפונק׳ מערכת (shell) בשם SendMail שמבצעת את השליחה:

```
void SendMailToUser (strUserMailAddress)
{
        Str = "Sendmail " + strUserMailAddress        # this lines constructs a string that
                                                      starts with "Sendmail" and ends with
                                                      the user's email address
        ...
        call Str          # invoke the command Str on the shell
}
```

1. הסבירו מהי הסכנה לבטיחות המערכת כתוצאה משימוש ב – SendMailToUser?
2. הסבירו כיצד ניתן למנוע את הבעיה.

<u>סעיף ב</u>

1. הסבירו ותנו דוגמה ל-SQLI
2. הסבירו ותנו דוגמאות לשני סוגי XSS שלמדנו

שאלה 2

א. תנו דוגמה לפגיעות Buffer Overflow אשר לא תיעצר ע״י אחת מההגנות הבאות (או שילוב שלהן):

ASLR – רנדומיזציה של פונקציות המערכת

DEP – מניעת הרצת קוד על המחסנית

CANARY – כתיבת ערך ע"י הקומפיילר לפני כתובת החזרה

הסבירו מדוע.

ב. הסבירו מהו וירוס פולימורפי וכיצד ניתן לזהותו.

ג. מה ההבדל בין IPS ל-IDS?

שאלה 3

א. נניח שבמע' Unix ישנו קובץ הרצה נגיש לכולם בשם dir המקבל כפרמטר שם של קובץ f ומבצע:
ls -l f ע"י שימוש בפונק' מערכת (כלומר בפועל מתבצעת הפקודה ls -l f של מע' ההפעלה).

נניח עוד כי קובץ זה הוא setuid ל-root. כיצד תוקף יכול להשתמש בקובץ זה בכדי לשנות את כל הקבצים בתיקייה מסוימת לנגישים לכל משתמש?
מדוע (האם) ללא הדרישה שהקובץ הוא setuid ל-root ההתקפה לא תעבוד?

ב. להלן מערכת חוקים לפיירוול (מסוג stateless):

- אפשר כל תקשורת היוצאת מן הארגון פרט ל-Telnet (פורט 23).
- אפשר כל תעבורת TCP מבחוץ אשר התחילה מתוך הארגון.
- אפשר תעבורת TCP מבחוץ לשרת האיימיילים (SMTP, פורט 25).
- אפשר תעבורת TCP מבחוץ לשרת ה-WEB (כלומר HTTP ו-HTTPS, פורט 80 ו-443).
- אפשר תעבורת TCP מבחוץ לשרת ה-SSH (פורט 22).

כתבו את החוקים המתאימים לפי הסינטקס שלמדנו בקורס. שים לב: יש לחסום כל תקשורת שלא מפורטת בחוקים הללו.

ג. האם תוכלו לחסום את כל האימיילים עם נושא ספציפי (למשל " Congratulations! You are the winner") עם פיירוול מסוג stateless? מה לגבי stateful? הסבירו.

שאלה 4

בשאלה זו נדון בהצעה לשיטת אימות זהות באינטרנט מבוססת קוקיות (cookies). השיטה נועדה לתת מענה טוב יותר לבטיחות ההתקשרות מול שרת רגיש, כגון בנק.

להלן תיאור השיטה:

כל התקשורת תתבצע מעל SSL, כלומר ב- HTTPS.

פתיחת חשבון (התקשרות ראשונית):

- תתבצע פתיחת חשבון ראשונית רגילה. כלומר המשתמש יגיע לבנק בכדי לקבל מסמכים שונים. לאחר מכן יתחבר לאתר HTTPS שכתובתו ניתנה לו, יכניס את הפרטים הנדרשים (פרטי זיהוי ופרטים שקיבל במסמכים), וכן יבחר שם משתמש וסיסמא.
- בנוסף, השרת יבחר מס' רנדומלי בן 256 ביט Rauth, וישמור אצלו את הרביעייה (AcctNum, UserName, Rauth, Hash(pwd)) לכל משתמש.
- השרת של הבנק ישמור קוקית בדפדפן של המשתמש שמכילה את Rauth.
- הקוקית תישמר כ-persistant וכ-Secure.
נזכיר: קוקית המוגדרת כ-persistant נשארת על הדיסק הקשיח של המשתמש גם לאחר ההתקשרות הנוכחית ועד למחיקה יזומה של הקוקית ע"י המשתמש או פקיעת תוקפה, כפי שהוגדר ע"י הבנק.
קוקית המוגדרת כ-Secure נשלחת רק בצורה מוצפנת (עם SSL).

- המשתמש יתבקש להכניס את כתובת האתר המאובטח ל"מועדפים" ובפעמים הבאות להיכנס לאתר דרך המועדפים.

התקשרות של משתמש רשום:

- המשתמש יזום התקשרות SSL ע"י בחירת האתר מן המועדפים.
- הדפדפן ישלח לאתר את הקוקית ב-SSL.
- המשתמש יכניס את פרטיו כרגיל (שם משתמש וסיסמא).
- אם פרטי המשתמש יאומתו וגם הקוקית תאומת (כלומר נשלח ה-Rauth הנכון) המשתמש יוכל להכנס לחשבונו.

דונו באספקטים השונים של שיטה זו. התייחסו לפחות לנק' הבאות:

- בטיחות: מה היתרון בשיטה זו על פני השיטה הרגילה (ללא קוקיות)? בפרט, האם יש התקפה שתצליח בשיטה הרגילה ותיכשל כאן? האם אין חשש שאתרים אחרים בהם מבקר המשתמש יכולים לקרוא את הקוקית של המשתמש? האם השיטה עמידה בפני התקפת מילון?
- שימושיות: מה קורה אם המשתמש מחק את המועדפים? מה אם הוא מחק את כל הקוקיות? מה אם הוא רוצה להתחבר ממחשב אחר?
- פרטיות: האם יש סכנה שפרט לשמירת קוקית, הבנק יקרא מידע ממחשב המשתמש? האם יש סכנה שאתרים אחרים יהיו מודעים לעצם קיום הקוקית של הבנק אצל המשתמש ובכך לקבל מידע פרטי (כלומר שלמשתמש זה יש חשבון בבנק XYZ)?

חוו דעתכם על השיטה.

שאלה 5

כידוע במהלך ביצוע שלב ההתקשרות הראשונית (Handshake) בפרוטוקול SSL (TLS) בין לקוח ושרת, הלקוח יכול לשלוח לשרת מפתח שהוא ייצר בעצמו, או לייצר אותו בצורה משותפת עם השרת.

א. באיזה פרוטוקול משתמשים לייצר את המפתח המשותף?

ב. האם תוקף אקטיבי יכול לבצע התקפת MITM במקרה זה? פרטו.

ג. נניח שהיוצר g שבו השתמשו בפרוטוקול הנ"ל הוא g=1. האם ההתקשרות בטוחה מפני תוקף פסיבי?

ד. נאמר שמפתח ה-RSA הציבורי של השרת הוא (1,N) עבור N=pq ראשוניים גדולים. האם ההתקשרות בטוחה מפני תוקף פסיבי?

ה. נניח שבסוף שלב ההתקשרות הלקוח והשרת סיכמו להשתמש ב-DES. האם ההתקשרות בטוחה מפני תוקף פסיבי?

ו. לאחר סיום שלב ההתקשרות (בצורה בטוחה) הלקוח מתבקש לשלוח את סיסמתו ואכן עושה זאת (ב-https). האם הסיסמה חשופה להתקפת אופליין ע"י תוקף פסיבי?

נמקו את תשובותיכם.

מטלת מנחה (ממ"ן) 05

הקורס: 20940 – מבוא לאבטחת המרחב המקוון

חומר הלימוד למטלה: מדריך הלמידה

מספר השאלות: 1 **משקל המטלה:** ללא נקודות

סמסטר: 2026A **מועד אחרון להגשה:** 17/01/2026

הוראות: נא להגיש במערכת המטלות בלבד.

שאלה 1 (100%)

עליכם להכין דו"ח המתאר אירועים בתחום אבטחת מחשבים אשר דווחו בכלי התקשורת ובאתרי אינטרנט שונים. רצוי לדווח על מקרים **חדשים ככל הניתן** (עד שנה אחורה).

עליכם **לדווח בקצרה** על 3-4 תקריות שכאלו, ולבחור מתוכן **תקרית משמעותית אחת**. עליכם להסביר את בחירתכם (מדוע התקרית משמעותית בעיניכם) ולפרט עבור תקרית זו את הבעיה **במונחים טכניים ברורים אך מתומצתים**. הפירוט יכלול לפחות את הפרטים הבאים:

איזו פגיעות נוצלה (אחת או יותר)? באילו שיטות נעשה שימוש בהתקפה? האם ניתן לפתור ו/או לעקוף את הבעיה? כיצד?

לסיכום הדו"ח עליכם לציין **בקצרה** אילו מקורות היו יותר מוצלחים מבחינתכם, לציין מגמות עכשוויות אשר הצלחתם לזהות, ולהוסיף את הרשמים האישיים ממעקב זה.

חשוב: אין להעתיק את הנתונים כמות שהם. יש לקרוא על התקרית במקורות השונים, להבין את הבעיה, ולתאר אותה כפי שנדרש לעיל, **במילים שלכם**, תוך איזכור המקורות. כמו כן, רעיונות המתקבלים מתלמידים אחרים חייבים להיות מצוטטים ככאלו.

<u>הדרכה נוספת</u>:

התחילו ע"י זיהוי והכרת המקורות בהם תשתמש למעקב זה, כגון CERT ו-Security focus, ועוד. בנוסף ניתן לבדוק אתרי אנטי וירוס כמו Symantec ו- McAfee, וכן אתרים של ספקיות תוכנה מובילות (כגון מיקרוסופט). כמו כן, גם בעיתונות הכללית ניתן למצוא דיווחים מעניינים, אם כי קשה לדלות מהם את הפרטים הטכניים. שימו לב כי ייתכן שתוכלו למצוא אתרים נוספים, אשר יהיו אולי טובים יותר לצרכיכם.

רצוי שלפחות תקרית אחת תהיה מהזירה המקומית. רצוי שלפחות תקרית אחת תהיה בתחום הפרטיות או בתחום האתי או בתחום קנין רוחני. רצוי שלא כל התקריות יהיו מאותו תחום.

לאחר איתור והבנת המידע המתאים, עליכם להסביר את הדברים במילים שלכם עם **מספיק פירוט בכדי להפגין את הבנתכם**. השתמשו בז׳רגון טכני, פרטי מערכת הפעלה וכו׳, ברמה המאפשרת הבנה ע״י תלמיד בקורס זה. התיאור אמור לעמוד בפני עצמו ולפיכך עליכם לכלול רקע קצר במקרה הצורך.

אם אתם מציעים פיתרון ניהולי העזרו בידע מפרק 1 במדריך (ומהפרקים הרלוונטיים ב-[SB]).
אם אתם מציעים פתרון טכני תוכלו להביא לידי ביטוי ידע ונסיון קודם שרכשתם.

מומלץ שהדו״ח יהיה בגבולות הבאים: כעמוד עבור דיווח התקריות השבועיות. עמ׳ עד שניים לפירוט התקרית המשמעותית. חצי עמ׳ עד עמ׳ לסיכום.